

Event Information:

EventID :

153

Event Time :

May, 29, 2023, 01:01 PM

Rule :

SOC202 - FakeGPT Malicious Chrome Extension

Level :

Security Analyst

Hostname :

Samuel

IP Address :

172.16.17.173

File Name :

hacfaophiklaeolhnmckojjjbnappen.crx

File Path :

C:\Users\LetsDefend\Download\hacfaophiklaeolhnmckojjjbnappen.crx

File Hash :

7421f9abe5e618a0d517861f4709df53292a5f137053a227bfb4eb8e152a4669

Command Line :

chrome.exe --single-argument

C:\Users\LetsDefend\Download\hacfaophiklaeolhnmckojjjbnappen.crx

Trigger Reason :

Suspicious extension added to the browser.

Device Action :

Allowed

Analysis Steps:

Logs were searched with IP 172[.]16.17.173 (Samuel) as the source in the relevant time-frame yielding 8 events.

The screenshot displays a security log viewer interface. At the top, a search bar contains the text "Source Address contains '172.16.17.173'", and a filter button labeled "All Time" is visible. Below the search bar, a status bar indicates "8 events (before May, 29, 2023, 01:06 PM UTC)". The main area shows a table of events. The first event is selected, and its details are displayed in a sidebar on the left. The event details include:

Field	Value
destination_port	0
time	May, 29, 2023, 01:02 PM
Raw Log	
Source	Sysmon
Username	Samuel
EventID	22
Type	DNS Query
QueryResult	::ffff:52.76.101.124::ffff:3.1.17.18::ffff:18.140.6.45;
QueryName	www.chatgptforgoogle.pro
Process	C:\Program Files\Google\Chrome\Application\chrome.exe
UtcTime	2023-05-29 13:02:47.838

At the bottom of the sidebar, it says "1 row selected".

From the network logs we can make the following conclusions regarding the alert:

At 01:02 PM, Samuel's machine made DNS and network connections to [www.chatgptforgoogle\[.\]pro](http://www.chatgptforgoogle[.]pro) 18[.]140.6.45 and [www.chatgptgoogle\[.\]org](http://www.chatgptgoogle[.]org) 52[.]76.101.124.

- These are highly suspicious domains. Threat actors frequently create fake websites mimicking trending AI tools to trick users into downloading malicious software.
- This is almost certainly where Samuel was tricked into downloading the malicious Chrome extension.

Shortly after visiting those sites, Samuel executed the downloaded file: `hacfaophiklaeolhnmckojjjbnappen.crx`.

- A .crx file is a standalone Google Chrome extension.
- The command line log shows Chrome was launched with the `--single-argument` flag pointing directly to this file, meaning Samuel manually installed this extension into his browser, bypassing the official Chrome Web Store.
- The long string of letters is the unique Extension ID.

Once the extension was installed, we see a shift in the network traffic.

- At 01:03 PM and again at 01:06 PM, the machine automatically queried `version.chatgpt4google.workers.dev`.
- Threat actors often abuse Cloudflare Workers (`.workers.dev`) to host C2 infrastructure. It is an evasion tactic where the traffic blends in with legitimate cloud services, making it harder for network filters to block.
- This traffic is likely the malicious extension either "phoning home" for instructions or actively exfiltrating Samuel's browser data.

The extension is listed as malicious by 8/60 Vendors on VirusTotal (3 days ago).

The screenshot shows the VirusTotal analysis page for the file `hacfaophiklaeolhnmckojjjbnappen.crx`. The file is identified as a Chrome extension (crx) with a size of 325.09 KB and was last analyzed 3 days ago. It has a community score of 8/60, with 8 vendors flagging it as malicious. The file name is `hacfaophiklaeolhnmckojjjbnappen.crx` and the check is for `chrome-extension`.

The **DETECTION** tab is active, showing a **Code insights** section. It lists the name as "ChatGPT for Google", the description as "Display ChatGPT response alongside search engine results", and the version as 1.16.6. A note mentions that the extension collects cookies from Facebook.com and sends them to `https://version.chatgpt4google.workers.dev/` via a custom X-Cache-Key HTTP header, which is flagged as unauthorized data-stealing behavior.

The **Crowdsourced AI** section shows a warning from Exodia Labs, stating that the extension is malicious because it collects cookies from Facebook.com and sends them to a custom endpoint, demonstrating unauthorized data-stealing behavior.

The **Threat categories** are listed as `hacktool` and `unknown`. The **Family labels** are also listed as `unknown`.

The **Security vendors' analysis** section shows the following results:

Vendor	Verdict
AICloud	HackTool.Unknown/BKF.Gen
ALYac	Application.Hacktool.BKF
Arcabit	Application.Hacktool.BKF
BitDefender	Application.Hacktool.BKF

None of the offending IPs or domains are in our CTI database and all are external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period.

VirusTotal indicates 18[.]140.6.45 is a Singapore address associated with 18[.]140.6.45 AS 16509 (Amazon.com, Inc.). 1/91 security vendors flagged this IP address as malicious.

1

Community Score

1/91

1/91 security vendor flagged this IP address as malicious

18.140.6.45 (18.128.0.0/12)
AS 16509 (Amazon.com, Inc.)

SG

Last Analysis Date
9 days ago

ReanalyzeMore

DETECTIONDETAILSRELATIONSCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

alphaMountain.ai	Malicious	Abusix	Clean
Acronis	Clean	ADMINUSLabs	Clean
AILabs (MONITORAPP)	Clean	AlienVault	Clean
Antiy-AVL	Clean	BitDefender	Clean

[www.chatgptforgoogle\[.\]pro](#) is listed as malicious by 2/91 Vendors.

2

Community Score

2/91

2/91 security vendors flagged this domain as malicious

www.chatgptforgoogle.pro
chatgptforgoogle.pro
Phishing and Other Frauds

Creation Date
3 years ago

Last Analysis Date
9 days ago

ReanalyzeMore

DETECTIONDETAILSRELATIONSCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

Fortinet	Malware	Webroot	Malicious
Abusix	Clean	Acronis	Clean
ADMINUSLabs	Clean	AILabs (MONITORAPP)	Clean
AlienVault	Clean	Antiy-AVL	Clean

VirusTotal indicates 52[.]76.101.124 is another Singapore address also associated with 18[.]140.6.45 AS 16509 (Amazon.com, Inc.). 0/91 security vendors flagged this IP address as malicious. This makes clear the attacker is making heavy use of trusted infrastructure to carry out their attacks.

[www.chatgptforgoogle\[.\]org](#) is listed as malicious by 7/91 Vendors and listed as being associated with phishing and fraud.

7

Community Score

7/91

7/91 security vendors flagged this domain as malicious

www.chatgptforgoogle.org
chatgptforgoogle.org
information technology phishing and fraud Phishing and Other Frauds

Registrar
GMO Internet Group, Inc. d/b/a Onamae.com

Creation Date
3 years ago

Last Analysis Date
1 month ago

ReanalyzeMore

DETECTIONDETAILSRELATIONSCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

BitDefender	Malware	Chong Lua Dao	Malicious
Fortinet	Malware	G-Data	Malware
Lionic	Phishing	Sophos	Phishing
Webroot	Malicious	Abusix	Clean

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a True Positive compromise of the endpoint Samuel (172[.]16.17.173) involving a malicious Chrome extension. The user was lured to fraudulent AI domains and manually installed a FakeGPT extension (hacfaophiklaeolhnmckojjjbnappen.crx) that actively harvests endpoint data and exfiltrates to an external server.

Incident Details

- **Alert Name:** SOC202 - FakeGPT Malicious Chrome Extension
- **Target Host:** Samuel (172[.]16.17.173)
- **File Name:** hacfaophiklaeolhnmckojjjbnappen.crx
- **Device Action:** Allowed

Analysis and Evidence

- **Initial Access:** Network logs show the user visited [www.chatgptforgoogle\[.\]pro](http://www.chatgptforgoogle[.]pro) and [www.chatgptgoogle\[.\]org](http://www.chatgptgoogle[.]org) at 01:02 PM. These are known fraudulent domains mimicking legitimate AI tools.
- **Execution:** Command line logs confirm the Chrome browser was launched with the --single-argument flag pointing to the .crx file in the user's Downloads folder. This confirms the user bypassed the official Chrome Web Store and manually installed the malicious extension.
- **Exfiltration / C2:** Following installation, the machine began querying [version.chatgpt4google\[.\]workers\[.\]dev](http://version.chatgpt4google[.]workers[.]dev). OSINT code analysis states the extension uses the `chrome.cookies.getAll` method to steal [facebook\[.\]com](http://facebook[.]com) session cookies, encrypts them via AES, and sends the payload to this Cloudflare Worker domain via a custom HTTP header.

Threat Intelligence

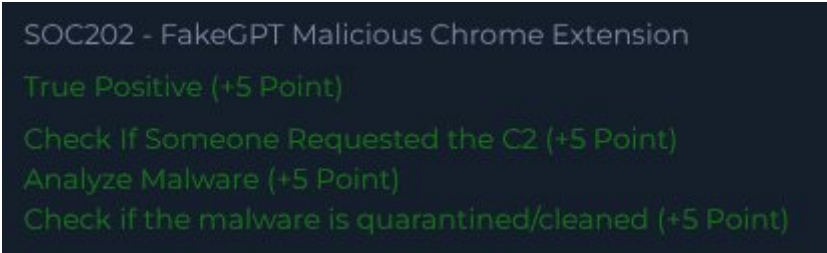
- **OSINT (File):** The .crx extension file is flagged as a malicious hacktool by 8/60 vendors on VirusTotal.
- **OSINT (Infrastructure):** The initial lure domains are flagged for phishing and fraud by up to 7/91 vendors. The domains are hosted on AWS infrastructure (AS 16509) located in Singapore (18[.]140.6.45 and 52[.]76.101.124). None of these IPs or domains are present in the internal CTI database.
- **Evasion:** The threat actor is heavily abusing trusted infrastructure (Amazon Web Services and Cloudflare Workers) to blend malicious traffic with legitimate cloud services.

Actions Taken

1. Analysed network logs to trace the origin of the malicious download to fraudulent FakeGPT domains.
2. Verified the manual installation of the malicious .crx extension via command-line telemetry.
3. Identified the malware's capabilities via OSINT code analysis, confirming it performs unauthorised cookie harvesting and exfiltration.
4. Declared the alert a True Positive and escalated.

Recommended Remediation: Force-remove the malicious extension from the browser, clear all active browser sessions/cookies on the host, and mandate a password reset for associated accounts (specifically Facebook) to invalidate any stolen session tokens.

Let's Defend Result



```
SOC202 - FakeGPT Malicious Chrome Extension
True Positive (+5 Point)
Check If Someone Requested the C2 (+5 Point)
Analyze Malware (+5 Point)
Check if the malware is quarantined/cleaned (+5 Point)
```